MODULE 26 · DOMAIN 6 - SECURITY AND COMPLIANCE

Network Defence in Depth

Security groups and network ACLs, WAF and Shield, Network Firewall and DNS Firewall, VPC endpoints, protecting origins, and Firewall Manager across an organisation.

DOMAIN 6 of 6 EXAM WEIGHT 17% MODULE 26 of 34

admin@sthithapragna.com

Defence in depth means every layer assumes the layer **outside it** has already failed.

The layers, from outside in

LAYER	CONTROLS
Edge	CloudFront, Shield, AWS WAF
Application entry	Load balancer or API Gateway, with AWS WAF
VPC perimeter	AWS Network Firewall; Route 53 Resolver DNS Firewall
Subnet	Network ACLs
Instance or task	Security groups
Private paths to AWS	VPC endpoints and their policies

ON THE EXAM

Match the attack to the layer that understands it: HTTP attacks to WAF, domains to Network or DNS Firewall, ports to groups.

Security group or network ACL?

SECURITY GROUP

Stateful, per interface

- Allow rules only
- Return traffic allowed automatically
- Can reference other security groups
- The main, everyday control

NETWORK ACL

Stateless, per subnet

- Allow and deny rules, numbered in order
- Return traffic needs its own rule
- Ephemeral ports must be allowed back out
- A coarse extra layer, or to deny an address

THE TIEBREAKER

Inbound works but responses fail: a stateless network ACL is missing its ephemeral-port rule.

Security groups, used well

- Reference **other security groups** rather than IP ranges: the database allows the app tier's group.
- Use **managed prefix lists** for sets of addresses, such as CloudFront's origin-facing list.
- Security group references now work across VPC peering and Transit Gateway.
- 0.0.0.0/0 on SSH or RDP is the finding every scanner and Config rule looks for.

> ON THE EXAM
>
> Instances scale in and out, so rules based on groups keep working while rules based on IPs go stale.

AWS WAF

- A **web ACL** protects CloudFront, ALB, API Gateway, AppSync, Cognito and more.
- **AWS managed rule groups** cover common exploits, SQL injection, known bad inputs and bad IPs.
- **Rate-based rules** throttle floods; **Bot Control** manages scrapers and bots.
- Start new rules in **count** mode, read the logs, then switch to block.

> ON THE EXAM
>
> SQL injection, scraping, request floods on an HTTP application: AWS WAF with managed rules and rate limits.

Shield Standard or Shield Advanced?

SHIELD ADVANCED

Paid, with a team behind it

- Access to the Shield Response Team
- Cost protection for attack-driven scaling
- Health-based detection and faster response
- Automatic application-layer mitigation with WAF

SHIELD STANDARD

Free, always on

- Network and transport layer protection
- Every AWS customer, automatically
- No configuration
- No response team, no cost protection

THE TIEBREAKER

Expert help during attacks, or protection from the bill an attack causes: Shield Advanced.

Network Firewall or DNS Firewall?

AWS NETWORK FIREWALL

Inspects the traffic itself

- Stateful and stateless rules; Suricata syntax
- Domain allow-lists by TLS server name
- Optional TLS inspection
- Needs routing through firewall subnets

ROUTE 53 RESOLVER DNS FIREWALL

Filters name lookups

- Blocks or allows domain resolution
- Managed lists of malicious domains
- No routing changes
- Bypassed by connecting to an IP directly

THE TIEBREAKER

Restrict outbound traffic to approved domains, robustly: Network Firewall. Block known-bad domains cheaply: DNS Firewall.

Gateway or interface endpoint?

GATEWAY ENDPOINT

S3 and DynamoDB only

- A route in the route table
- No hourly or data charge
- Same Region only
- Controlled with an endpoint policy

INTERFACE ENDPOINT

Most other services

- A network interface with private IPs
- Charged per hour and per GB
- Reachable from on-premises and peered networks
- Security groups plus an endpoint policy

THE TIEBREAKER

Private S3 access at the lowest cost: a gateway endpoint. Private access to Secrets Manager or ECR: interface endpoints.

A bucket that only answers through the endpoint

```
{ "Sid": "OnlyThroughOurEndpoint",
  "Effect": "Deny",
  "Principal": "*",
  "Action": "s3:*",
  "Resource": ["arn:aws:s3:::payroll-data", "arn:aws:s3:::payroll-data/*"],
  "Condition": {
    "StringNotEquals": { "aws:SourceVpce": "vpce-0a1b2c3d4e5f60718" } } }
```

2 An explicit deny, so no other allow can override it.

7 Any request not arriving through this endpoint is refused.

ON THE EXAM

The endpoint policy limits what goes out; the bucket policy limits what comes in. Use both for a tight perimeter.

Protecting origins from being bypassed

- S3 origins: **origin access control**, so the bucket only answers CloudFront.
- ALB, NLB or EC2 origins: **CloudFront VPC origins** (November 2024) keep them in private subnets.
- Older pattern: a public load balancer that checks a secret custom header, plus the CloudFront prefix list.
- A public origin can always be reached directly, around your edge WAF, unless something stops it.

ON THE EXAM

Attackers bypass CloudFront by calling the load balancer directly: make it a VPC origin, with no public endpoint at all.

Stopping exposure before it happens

- **VPC Block Public Access** (November 2024) blocks internet gateway traffic for VPCs and subnets, with exclusions.
- Enforced across an organisation through a **declarative policy**, as in module 12.
- S3 Block Public Access and EBS snapshot block public access do the same for storage.
- **Reachability Analyzer** explains why one resource can or cannot reach another.

> ON THE EXAM
>
> 'Why can't this instance reach that database?': Reachability Analyzer traces the path and names the blocker.

AWS Firewall Manager

- Applies firewall policies across every account in an organisation, from a delegated administrator.
- Covers WAF, Shield Advanced, security groups, Network Firewall and DNS Firewall.
- New accounts and new resources receive the policy automatically; non-compliant ones can be remediated.
- WAF policies can run first and last rule groups, leaving room for each team's own rules.

ON THE EXAM

The same baseline WAF rules on every load balancer in every account, including future ones: Firewall Manager.

> A web application uses CloudFront with AWS WAF in front of an internet-facing Application Load Balancer. Security finds attackers sending requests straight to the load balancer's DNS name, bypassing WAF.
>
> The company wants the strongest fix with the least ongoing operational effort.

What should the DevOps engineer do?

A. Add a secret custom header in CloudFront, check it on the load balancer, and rotate it regularly

B. Restrict the load balancer's security group to the CloudFront managed prefix list

C. Attach a second copy of the WAF web ACL to the load balancer

D. Move the load balancer to private subnets and make it a CloudFront VPC origin

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A Secret header

Works, but the secret needs rotating, and the load balancer stays public.

B Prefix list only

Any CloudFront distribution, including an attacker's, can still reach it.

C Second WAF

Double cost and rules; the direct path still exists.

D VPC origin

No public endpoint remains to bypass; CloudFront is the only way in.

THE SIGNAL

Bypass around the edge: remove the path. VPC origins make the load balancer unreachable except through CloudFront.

> A public API behind an Application Load Balancer faces SQL injection attempts, aggressive scraping by bots, and bursts of requests from single addresses.
>
> The team wants protection with the least operational overhead and no custom rule writing.

What should the DevOps engineer deploy?

A. An AWS WAF web ACL on the load balancer with AWS managed rule groups, Bot Control, and a rate-based rule

B. Network ACL deny rules for each attacking address

C. Tighter security group rules on the load balancer

D. AWS Network Firewall in front of the load balancer

◆ PAUSE AND DECIDE

What should the DevOps engineer deploy?

A WAF with managed rules

Managed rules catch injection, Bot Control handles scrapers, and a rate rule throttles bursts.

B NACL denies

Endless manual address lists, a small rule limit, and blind to request contents.

C Security groups

Allow-only, by port and address. They cannot see SQL in a request.

D Network Firewall

A network-layer inspector. HTTP attacks belong to WAF.

THE SIGNAL

Attacks inside HTTP requests: WAF. Every other option works below the layer where the attack lives.

> Build servers in private subnets must only reach a short list of approved domains over HTTPS, such as a package registry and a code host. All other outbound traffic must be blocked, even to raw IP addresses.
>
> The team wants a managed solution.

What should the DevOps engineer use?

A Network ACL outbound rules

B AWS Network Firewall with a stateful domain allow-list, with the subnets routed through it

C Security group outbound rules

D Route 53 Resolver DNS Firewall alone

◆ PAUSE AND DECIDE

What should the DevOps engineer use?

A Network ACLs

Addresses and ports only. They cannot match domain names.

B Network Firewall domain allow-list

Matches the TLS server name and drops everything else, including raw IPs.

C Security groups

Addresses and ports only, and addresses behind domains change constantly.

D DNS Firewall alone

Blocks name lookups, but a connection to a raw IP skips DNS entirely.

THE SIGNAL

Egress by domain, robust to direct IPs: Network Firewall. The phrase 'even to raw IP addresses' rules out DNS Firewall.

> A company has 100 accounts in AWS Organizations. Every Application Load Balancer and CloudFront distribution must have a baseline set of WAF rules, including in accounts created later.
>
> Application teams must still be able to add their own WAF rules.

Which solution meets these requirements with the LEAST operational overhead?

A. A StackSet that deploys a web ACL to every account

B. An AWS Config rule that reports load balancers without WAF

C. An AWS Firewall Manager WAF policy from a delegated administrator, with baseline rule groups first and room for team rules

D. An SCP that denies creating load balancers without WAF

◆ PAUSE AND DECIDE

Which solution meets these requirements with the LEAST operational overhead?

A StackSet web ACLs

Creates web ACLs, but does not associate them with every new resource.

B Config rule

Reports the gap. Fixes nothing.

C Firewall Manager

Applies baseline rules to every resource in every account, new ones included, leaving room for team rules.

D SCP

Cannot see whether a load balancer will have WAF attached.

THE SIGNAL

Firewall rules everywhere, including future accounts and resources, with team rules allowed: Firewall Manager.

> Instances in private subnets upload large volumes of data to an S3 bucket through a NAT gateway, and the NAT data charges are high. The bucket must also refuse any request that does not come from this VPC.
>
> The company wants the lowest cost.

What should the DevOps engineer do?

A. Add an S3 gateway endpoint, and a bucket policy denying requests not from that endpoint

B. Add a second NAT gateway

C. Add an S3 interface endpoint, and a bucket policy denying requests not from that endpoint

D. Make the bucket public, with a condition on the NAT gateway's IP address

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A Gateway endpoint and bucket policy

No charge for the endpoint or its data, and the policy locks the bucket to it.

B Second NAT gateway

Doubles the charges.

C Interface endpoint

Works and is private, but charges per hour and per GB. Not lowest cost.

D Public bucket

Never. Public exposure for a private workload.

THE SIGNAL

Private S3 or DynamoDB access at the lowest cost: a gateway endpoint. Interface endpoints cost money.

> A team adds an inbound network ACL rule allowing HTTPS on port 443 to a public subnet's web servers. Security groups allow 443 in. Requests reach the servers, but clients never receive responses.
>
> The network ACL's outbound rules allow only port 443.

What should the DevOps engineer change?

A. Add an outbound rule to the instances' security group

B. Add an outbound network ACL rule allowing ephemeral ports 1024-65535 to clients

C. Allow all traffic in both directions in the network ACL

D. Add a route to the internet gateway

◆ PAUSE AND DECIDE

What should the DevOps engineer change?

A **Security group outbound**

Security groups are stateful: responses are already allowed.

B **Ephemeral ports outbound**

Responses go to the client's ephemeral port, which the stateless ACL must allow.

C **Allow everything**

Works by removing the control.

D **Route to the gateway**

Requests already arrive, so the route exists.

THE SIGNAL

Requests arrive, responses vanish, a network ACL is involved: stateless rules need the ephemeral return path.

Module 26 in five lines

- Every layer assumes the outer one failed. Put each attack at the layer that understands it.
- Security groups are stateful and reference groups; network ACLs are stateless and can deny.
- WAF for HTTP attacks; Shield Advanced for DDoS help; Network Firewall for egress by domain.
- Gateway endpoints for cheap private S3 and DynamoDB; aws:SourceVpce locks buckets to them.
- VPC origins remove bypass paths; Firewall Manager applies it all across the organisation.

> ON THE EXAM
>
> Next, module 27: detection and posture at scale. GuardDuty, Security Hub, Inspector, Macie and Detective.